

1. Executive Summary

NexusTech Solutions has grown from 50 to 250 employees and now serves financial and healthcare clients, but its security documentation remains concentrated in a five-year-old “IT Rules” document. The brief identifies three governance weaknesses: mixed levels of documentation, unclear accountability and compliance gaps. The response in this report separates policy intent from mandatory technical requirements, recommended guidance and operational procedures. This creates a maintainable documentation hierarchy and provides an evidence trail from management direction to day-to-day execution.

The five evidence bundles apply a Security Policy Development Lifecycle: identify the business and security need; define scope and requirements; draft and classify documentation; review and approve; communicate and implement; monitor compliance and effectiveness; and review, revise or retire documentation when triggers occur. This approach is consistent with the governance emphasis in NIST CSF 2.0, which treats cybersecurity strategy, expectations and policy as governance activities that are established, communicated and monitored (NIST, 2024).

2. Evidence Bundle 1 - Security Policy Hierarchy

2.1 Hierarchy Definitions

Document Type	Purpose	Authority	Mandatory/Recommended	Level of Detail
Policy	States management direction, security objectives, required behaviour, and governance expectations.	Approved by the designated management authority (e.g., CEO, Board); applies organisation-wide or to a defined scope.	Mandatory once approved.	High-level: Defines what must be protected or achieved and why; avoids operational steps.
Standard	Defines mandatory minimum requirements and baselines supporting a policy (e.g., password length, encryption standards).	Approved through the security governance process and owned by the responsible control/technical function.	Mandatory where applicable.	Medium: Specifies measurable requirements, technical baselines, and minimum configurations.
Guideline	Provides recommended	Issued by the	Recommended,	Medium: Practical

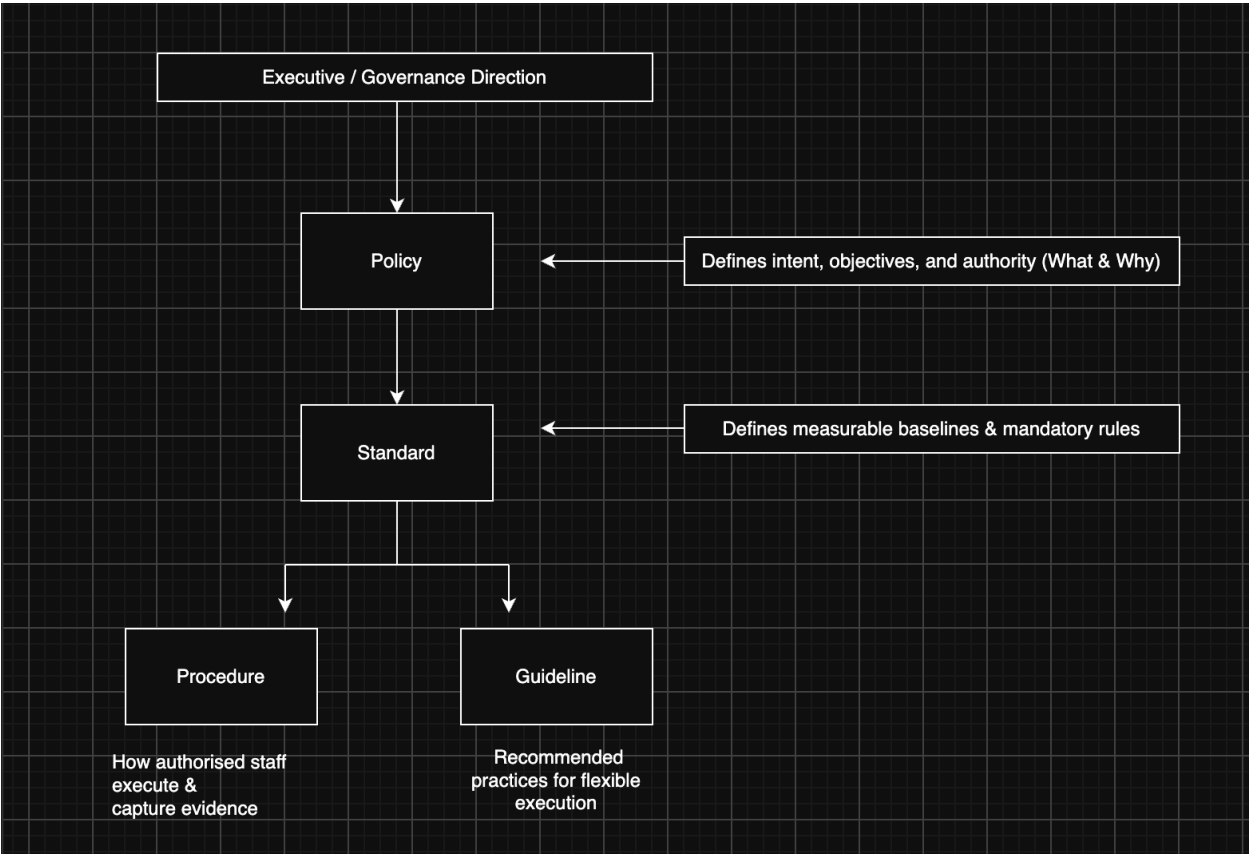
	practices to aid decision-making when multiple operational approaches are acceptable.	relevant security or technical domain owner under policy authority.	unless explicitly incorporated into a policy or standard.	advice, illustrative examples, and preferred approaches.
Procedure	Defines repeatable, step-by-step tasks to perform an activity and generate audit evidence.	Owned by the operational function (e.g., IT Helpdesk); must align with governing policy and standards.	Mandatory for the specific process being performed.	Detailed: Specifies who does what, in what sequence, what evidence is captured, and completion criteria.

2.2 Classification of NexusTech Draft Statements

no.	Draft Statement	Classification	Justification
1.	All NexusTech employees must use MFA when accessing the corporate network remotely.	Policy	It establishes a mandatory organization-wide security rule regarding access behavior without prescribing technical configuration steps.
2.	To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	It provides step-by-step operational instructions for completing a specific configuration task.
3.	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	It offers advisory secure-coding advice using non-mandatory language ("recommended").
4.	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	It states executive intent and foundational security objectives rather than operational or technical rules.
5.	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	It sets a mandatory, measurable technical baseline specifying designated encryption software.
6.	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	It uses advisory wording ("should") to guide user risk decisions during travel without imposing a rigid technical control.
7.	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	It specifies an immediate operational action step triggered by an incident event.

8.	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	It defines quantifiable, testable technical parameter constraints for system enforcement.
----	---	----------	---

2.3 Policy Hierarchy Diagram



Flow Principle: Policy establishes management intent and authority; standards convert that intent into measurable specifications; procedures operationalize standards into repeatable tasks; guidelines offer flexible implementation advice. Lower-level documentation must remain consistent with parent policies.

2.3 Security Policy Development Lifecycle (NexusTech Context)

Lifecycle Stage	NexusTech Application	Output / Evidence
1. Initiation & Assessment	Identify legacy 5-year-old "IT Rules" document, rapid growth (50 to 250 users), and compliance drivers (SOC 2, ISO 27001 readiness).	Project Charter & Business Requirements Scope.
2. Risk & Requirements	Evaluate remote work risks,	Risk Analysis Summary &

Analysis	cloud ERP data protection, and identity governance gaps.	Compliance Mapping.
3. Drafting & Structuring	Separate overarching policy requirements from technical standards, operational procedures, and guidelines.	Draft Bundles 1–3 (AUP & Access Request Procedure).
4. Review & Approval	Consult IT Director Sarah Jenkins, HR, Legal, and obtain sign-off from CEO Marcus Vance.	Formal Stakeholder Approval & Version 1.0 Sign-off.
5. Communication & Deployment	Roll out organization-wide training, collect user attestations, and train Helpdesk teams.	Communication Plan & Attestation Tracking (Bundle 4).
6. Monitoring & Enforcement	Track Helpdesk ticket quality, MFA compliance rates, and process security exception requests.	Security Metrics Dashboard & Audit Evidence Log.
7. Review & Maintenance	Conduct annual reviews or trigger early updates following infrastructure changes or security incidents.	Annual Review Memo & Version Control Log (Bundle 5).

3. Evidence Bundle 2 - NexusTech Acceptable Use Policy

Document Control	Approved value
Title	Acceptable Use Policy
Document ID	NTS-ISP-AUP-001
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	17 September 2026
Review Date	17 September 2027, or earlier if a review trigger occurs
Classification	Internal — Company Policy
Related artefacts	Access Control Policy; User Access Request Procedure; Incident Response Procedure; Data Classification and Handling Policy

Purpose

The purpose of this Acceptable Use Policy (AUP) is to establish clear, mandatory rules governing the secure and responsible use of NexusTech Solutions (“NexusTech”) information assets, technology infrastructure, corporate networks, company-provided devices, applications, and cloud services.

This policy is designed to mitigate malware infections, unauthorized data disclosure, regulatory non-compliance, and operational disruptions, while supporting employees and authorized third parties in performing legitimate business activities.

Scope

This policy applies to:

- All NexusTech employees, contractors, interns, consultants, temporary staff, and authorized third parties who access NexusTech systems, accounts, or information assets.
- All company-owned, managed, or leased endpoints (laptops, mobile devices, servers), corporate accounts, network infrastructure, web applications, cloud environments (e.g., AWS, ERP systems), and data repositories.
- Remote access, on-premises connectivity, and authorized personal devices used for business activities.

Policy Statements

- **Acceptable & Authorised Use**
 - **Business Alignment:** Technology resources provided by NexusTech must be used primarily for legitimate business purposes in compliance with applicable laws, contractual commitments, and corporate policies.
 - **Credential Protection:** Users must safeguard their unique authentication credentials (user IDs, passwords, tokens, API keys) and must never share or disclose them.
 - **Mandatory Authentication:** Multi-Factor Authentication (MFA) must be used wherever required by NexusTech security configurations. Bypassing or attempting to disable MFA is strictly prohibited.
 - **Authorized Software Only:** Users must install and execute only software, browser extensions, and cloud applications that have been formally reviewed, approved, and authorized through the standard IT approval process.
 - **Data Confidentiality:** Users must access, process, share, or delete sensitive business or client data strictly on a need-to-know basis as required for their specific role.
- **Prohibited Activities**
 - **Unapproved Software & Content:** Downloading, installing, storing, or executing malicious, unapproved, pirated, or unlicensed software is explicitly forbidden.
 - **Unauthorized Access & Testing:** Users must not attempt to access systems, data, or accounts for which they lack explicit authorization, nor perform unauthorized vulnerability scans, penetration tests, or system monitoring.

- **Data Exfiltration:** Transferring sensitive, confidential, or proprietary NexusTech or client information to personal email accounts, personal cloud storage services (e.g., Dropbox, personal Google Drive), unapproved messaging platforms, or external repositories is strictly prohibited.
 - **Security Control Interference:** Users must not disable, modify, or interfere with endpoint security tools, antivirus/EDR agents, disk encryption software (BitLocker/FileVault), logging tools, or patch management systems without explicit authorization from IT/Security.
 - **Unlawful & Disruptive Conduct:** Using NexusTech systems to conduct illegal activities, harassment, discrimination, fraud, copyright infringement, spamming, or deliberately impairing network availability is prohibited.
- **Reasonable Personal Use**
Conditions for Use: Occasional, incidental personal use of NexusTech endpoints and network access is permitted provided it:
 - Remains reasonable, legal, and non-disruptive to work duties.
 - Does not consume excessive bandwidth or storage resources.
 - Does not introduce malware, operational risk, or reputational damage.
 - Strictly complies with all prohibited activity rules defined in Section 3.2.
 - **Incident Reporting**
 - Users must immediately report any known or suspected security incident(including lost/stolen corporate devices, compromised credentials, accidental data leaks, or suspicious phishing emails)to the IT Helpdesk / Security Team via approved channels.

Roles and Responsibilities

Roles	Responsibilities
All users	Read and comply with the AUP; complete required training; protect credentials and information; report suspected incidents; request approval where required.
Managers	Ensure team members understand role-specific requirements; support training completion; approve legitimate access and business needs; escalate repeated non-compliance.
IT / Information Security	Maintain technical controls; provide guidance; monitor security events where authorised; investigate suspected misuse; maintain procedures and evidence.
Human Resources	Support onboarding, disciplinary processes and offboarding where policy violations or employment actions are involved; coordinate with Information Security and management.

Information Security Manager	Own the policy; coordinate reviews; maintain governance records; monitor effectiveness; recommend revisions and exceptions.
CEO / Executive approval authority	Approve the policy and material revisions and provide management direction for enforcement and risk acceptance.

Compliance and Enforcement

- **Assurance & Monitoring:** Compliance with this policy is verified through automated technical controls, logging, periodic security audits, access reviews, and training attestation records.
- **Enforcement & Disciplinary Action:** Non-compliance or deliberate violation of this policy presents significant risk to NexusTech assets and client trust. Depending on the severity, intent, and impact of the breach, failure to comply may result in:
 - Remedial education and security coaching.
 - Temporary or permanent revocation of access privileges.
 - Formal disciplinary proceedings in coordination with HR, up to and including termination of employment or contract.
 - Legal action or referral to law enforcement authorities where applicable.

Policy Exceptions

- **Formal Approval:** Exceptions to this policy are permitted only when driven by a legitimate, documented business necessity that cannot be met through standard controls.
- **Workflow:**
 1. The requester submits an explicit Exception Request documenting the business case, scope, impacted assets, and proposed risk mitigations.
 2. The Information Security Manager assesses the security risk and defines required compensating controls.
 3. Formal sign-off must be obtained from the Information Security Manager and the relevant business/system owner.
- **Lifecycle:** Approved exceptions are temporary, must specify an expiration date (not to exceed 12 months), and must be reviewed prior to renewal.

Approval and Review

This policy has been formally reviewed and approved by executive management.

Approver Title	Name	Signature / Approval Status	Date
Chief Executive Officer	Marcus Vance	Approved (Formal Sign-off)	17 September 2026
Information Security Manager	Sisanda Lisa Masango	Submitted for Governance Review	17 September 2026

Review Cycle: This policy shall be reviewed at least annually. An immediate out-of-cycle review will be triggered by significant changes to NexusTech's technology architecture (e.g., major cloud migrations), emerging legal/regulatory requirements, or following a major security incident.

4. Evidence Bundle 3 - User Access Request Procedure

Document Control	Entry
Title	User Access Request Procedure
Document ID	NTS-ISP-PRO-ACR-001
Version	1.0
Owner	IT Service Desk / Information Security
Approving authority	Information Security Manager
Applies to	Employees, contractors and other authorised users requiring NexusTech system access
Related policy	Access Control Policy and Acceptable Use Policy

Purpose

- **Purpose:** Defines the mandatory, repeatable steps for receiving, verifying, approving, provisioning, recording, and closing user access requests across NexusTech systems. This procedure eliminates informal access provisioning (e.g., via chat, verbal requests, or direct email) to enforce least privilege and preserve auditability.
- **Scope:** Applies to all requests for new user accounts, role modifications, elevated permissions, temporary contractor access, and third-party access across corporate networks, endpoints, applications, and cloud environments (e.g., AWS, ERP).

Prerequisites & Authorisations

Before executing any provisioning step, the following prerequisites must be met:

1. **Ticketing System:** An active ticket must exist in the designated IT Service Management (ITSM) platform.
2. **Identity Verification:** The target user must be verified against HR record sources.
3. **Approval Matrix:**
 - **Standard Access:** Line Manager approval required.
 - **Sensitive / Cloud / ERP Access:** Line Manager + Data/System Owner approval required.
 - **Administrative / Privileged Access:** Line Manager + System Owner + Information Security approval required.
4. **Technician Authority:** Technicians must hold explicit administrative rights for the target system being configured.

Step-by-Step Operating Procedure

Step	Required action
1. Receive the request	Accept only requests submitted through the approved ticketing/workflow channel. Do not provision access solely from informal email, chat or verbal requests.
2. Check completeness	Confirm the ticket identifies the user, employment/contract status, system/application, requested role or permission, business justification, requested start date and end/expiry date where applicable.
3. Verify identity and employment status	Confirm the requester and target user against the authorised identity/HR source available to the Helpdesk. If the status cannot be verified, stop processing and escalate.
4. Verify manager approval	Check that the user's authorised manager has approved the exact access requested. Do not accept approval that is ambiguous or does not cover the requested system/role.
5. Verify system/data-owner approval	Where the system or information requires it, confirm approval from the designated system or data owner. Record the approver and approval timestamp in the ticket.
6. Validate least privilege	Determine the minimum role or permissions required to perform the stated business function. Reject or return requests for unnecessary privileges for clarification.
7. Check for segregation-of-duties conflicts	Where applicable, compare the requested access against incompatible roles or duties. Escalate conflicts to the designated owner rather than overriding the control informally.
8. Create or update the account	Using the approved administration process, create the account or modify the existing account at a high level according to the approved role. Apply required authentication and security controls.
9. Assign role-based permissions	Assign only the approved role/permission set. Do not add administrative or unrelated privileges for convenience.
10. Apply lifecycle dates	Set start, expiry or review dates where the access is temporary, contractor-based or otherwise time-limited.

11. Validate the result	Confirm that the provisioned access matches the approved request. Where appropriate, perform a controlled access test without exposing sensitive information.
12. Notify the user and manager	Notify the user and relevant manager that access has been provisioned, using the approved communication channel. Do not send passwords or sensitive credentials in insecure messages.
13. Capture evidence	Record the approvals, identity verification, role assigned, provisioning date, administrator, relevant system evidence and any exception or escalation in the ticket.
14. Close the ticket	Confirm all required evidence is present, mark the request as completed, record the completion date and close the ticket. Incomplete requests must remain open or be returned to the requester.
15. Retain the audit trail	Retain the ticket and associated evidence according to NexusTech record-retention requirements so that the organisation can demonstrate who requested, approved, provisioned and reviewed access.

Emergency & Exceptional Access Handling

- **Trigger:** Permitted only during critical production outages or active security incidents where standard lead time causes severe business operational impact
- **Emergency Workflow:**
 - Technician opens an Emergency Access Ticket (Severity 1).
 - Verbal or immediate written approval must be obtained from the Information Security Manager or On-Call IT Lead prior to provisioning.
 - Provision time-bound access (maximum 24-hour automatic expiration).
 - Retrospective Review: Within 24 hours of incident resolution, the system owner and Information Security Manager must perform a formal retrospective audit of all actions taken under emergency access.

Process Completion Criteria

A User Access Request is considered successfully completed only when:

- Full authorization (Manager + System Owner) is captured in writing.
- Provisioned access adheres strictly to RBAC and least-privilege principles.
- System configuration matches ticket specifications without scope creep.
- The user receives credentials securely, and audit evidence is permanently logged in the ticket.

5. Evidence Bundle 4 - AUP Communication and Training Plan

The rollout approach recognises that publishing a PDF alone does not demonstrate understanding or adoption. Communication therefore combines leadership messaging, role-specific training, acknowledgement, knowledge checking and follow-up. This supports the governance principle that security expectations and policies should be communicated and monitored (NIST, 2024).

Audience	Key message	Channel	Owner	Timing	Acknowledgement / evidence	Success measure
All employees	The AUP defines acceptable use, prohibited behaviour, reasonable personal use, reporting duties and consequences.	CEO announcement; all-hands session; intranet; email.	CEO + Information Security Manager	Day 1–2	Electronic policy acknowledgement and training registration.	≥95% announcement reach; 100% acknowledgement by deadline.
IT / Helpdesk / Security	Technical teams must enforce the AUP consistently and use the approved access, exception and incident workflows.	Role-specific workshop; procedure walkthrough; intranet knowledge base.	Information Security Manager + IT Manager	Day 2–4	Training attendance plus knowledge check.	100% completion; ≥80% knowledge-check score; unresolved questions tracked.
Managers	Managers must reinforce acceptable use, approve legitimate business needs and escalate repeated non-compliance.	Manager briefing; short guide; live Q&A.	Information Security Manager + HR	Day 3–5	Manager attestation.	100% manager completion; escalation route understood.
New starters	AUP requirements apply from onboarding and must be understood before normal	Onboarding module; e-sign acknowledgement.	HR + Information Security	Ongoing from Day 5	Signed/electronic acknowledgement linked to onboarding record.	100% new-starter acknowledgement before or at required onboarding stage.

	access is granted.					
Contractors / relevant third parties	Access is conditional on following NexusTech security requirements and contractual obligations.	Contractor briefing; acknowledgment workflow.	Procurement / Manager + Information Security	Day 4–7	Contractual acknowledgment or attestation.	100% applicable third parties recorded; exceptions identified and reviewed.

Rollout timeline

Period	Activity	Output
Day 1	CEO announcement and policy publication.	Official announcement; policy available in controlled repository.
Days 2–3	All-hands awareness session and employee Q&A.	Attendance record; FAQ/issues log.
Days 2–4	IT/Security role-specific training and procedure walkthrough.	Training completion and knowledge-check results.
Days 3–5	Manager briefing and HR alignment.	Manager attestations; escalation guidance.
Days 4–7	Mandatory employee learning module and AUP acknowledgement.	Completion and acknowledgement report.
Day 10	First compliance review and targeted reminders.	Outstanding-user list; remediation actions.
Day 30	Effectiveness review.	Completion, acknowledgement, knowledge and incident/exception trend report.

Non-compliance and misunderstanding escalation

Outstanding training or acknowledgement is first addressed through automated reminders and manager follow-up. Continued non-compliance is escalated to the relevant manager and HR where appropriate. Repeated misunderstanding is addressed through targeted coaching or additional training. Suspected deliberate or material policy violations are handled through the incident and enforcement process, with Information Security and HR/legal involvement where required.

Effectiveness measures

- Training completion and policy acknowledgement rate by audience.
- Knowledge-check pass rate and recurring questions indicating misunderstanding.
- Number and type of AUP-related incidents, exceptions and repeat violations after rollout.
- Time taken to resolve outstanding training/acknowledgement items.

6. Evidence Bundle 5 - Policy Review and Maintenance Memo

Memo field	Entry
To	Information Security Steering Committee
From	Information Security Manager
Date	17 September 2027
Subject	Review of Acceptable Use Policy following AWS migration and personal-cloud sharing incident

The Acceptable Use Policy should be formally reviewed because two defined review triggers have occurred. First, NexusTech has migrated its primary database to AWS, materially changing the technology environment and the locations and services through which company and client information may be accessed. Second, an employee shared a sensitive document through a personal cloud-storage account. The incident provides evidence that the existing acceptable-use wording should be tested against an actual information-handling failure. These events warrant an earlier review rather than waiting for the normal annual review date.

The review should begin with consultation involving Information Security, IT/cloud engineering, system and data owners, HR, legal/contract stakeholders where relevant, and representative business managers. The review team should examine the incident record, existing exceptions, training and acknowledgement results, access-control evidence, cloud-use arrangements and relevant audit findings. A risk analysis should then determine whether the current controls and wording adequately address personal cloud services and cloud-hosted business information. The revised draft should be reviewed by affected stakeholders, approved through the established governance route, version-controlled and communicated to users before the effective date.

Two specific updates are proposed. First, the AUP should explicitly prohibit storing or transferring confidential, sensitive or client information to personal cloud-storage accounts and should require use of NexusTech-approved cloud services. Second, the policy should define acceptable use of corporate cloud services, including requirements to use authorised accounts, protect shared information and follow applicable access and data-handling controls. The Information Security Manager remains policy owner, with approval routed to the CEO as the designated approval authority. Following this review, the policy should return to an annual review cycle, with an early review triggered by material cloud/technology changes, significant security incidents or data disclosures, major organisational changes, material audit findings, or changes in applicable legal or contractual requirements.

Conclusion

The proposed framework addresses the core governance problem identified at NexusTech: one outdated document was being used to express management intent, define technical requirements and instruct staff. Separating Policies, Standards, Guidelines and Procedures creates clearer authority, accountability and maintenance boundaries. The AUP establishes enforceable user behaviour; the User Access Request Procedure translates access governance into repeatable actions and evidence; the Communication and Training Plan supports adoption; and the Review Memo demonstrates how policy is maintained when technology and risk change.

Together, the five evidence bundles provide a controlled policy lifecycle rather than a one-time documentation exercise. This is also consistent with NIST CSF 2.0's governance emphasis and can support NexusTech's broader readiness activities without claiming that the artefacts alone constitute ISO/IEC 27001 certification or SOC 2 compliance.

References

- Nieves, M., Dempsey, K., & Pillitteri, V. (2017). An introduction to information security (NIST Special Publication 800-12 Rev. 1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-12r1>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). <https://doi.org/10.6028/NIST.CSWP.29>
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection - Information security management systems - Requirements.
- International Organization for Standardization. (2022). ISO/IEC 27002:2022 - Information security, cybersecurity and privacy protection - Information security controls.
- American Institute of Certified Public Accountants & CIMA. (2023). 2017 Trust Services Criteria (with revised points of focus - 2022).

Source note: The assessment brief supplied for this laboratory is the primary scenario and marking source. It specifies the five evidence bundles, required contents, submission standards and academic-integrity requirements. fileciteturn0file0L164-L178

Evidence Checklist

- Evidence Bundle 1: definition table, all eight classifications with justifications, hierarchy diagram and lifecycle application.
- Evidence Bundle 2: complete Acceptable Use Policy with purpose, scope, requirements, roles, compliance, enforcement, exceptions, approval and review.
- Evidence Bundle 3: sequential User Access Request Procedure covering intake, approvals, account creation, RBAC, least privilege, notification, evidence, closure and exceptions.
- Evidence Bundle 4: communication and training plan covering audiences, messages, channels, owners, timeline, acknowledgement and effectiveness measures.
- Evidence Bundle 5: 2–3 paragraph review memo covering triggers, review process, proposed updates, owner/approval route and future review requirements.